

EXTERNAL WEB SECURITY

Website Penetration Testing Report

Orange Tunisia web assets and chatbot infrastructure

OVERALL EXTERNAL RISK

MEDIUM

Four validated weaknesses; no critical unauthenticated compromise demonstrated

FRONT MATTER

Document Control

Ownership, handling, versioning, and source limitations for this professional edition.

Document metadata

Client	Orange Tunisie
Target	www.orange.tn; chatbot.orange.tn

Interpretation rule

EVIDENCE FIRST

Validated weaknesses, contextual observations, negative test results, pending hypotheses, and assessment limitations are reported separately. A scanner alert, exposed technology, or untested attack scenario is not presented as a confirmed exploit.

FRONT MATTER

Contents

01	Executive Summary	3
02	Engagement Overview	5
03	Methodology and Risk Model	8
04	Validated Findings	10
05	Security Observations	14
06	Negative and Pending Tests	17
07	Remediation Roadmap	19

How to read this report

Label	Meaning
Validated finding	A weakness directly supported by response, header, TLS, or scanner evidence.
Observation	A proven condition that increases risk or warrants hardening, but is not a proven exploit.
Negative test	A tested attack class for which no security impact was demonstrated.
Pending validation	A material hypothesis requiring authenticated, backend-assisted, or deeper business-logic testing.

01

Executive Summary

Management view of validated risk, important uncertainty, and the actions that should happen first.

OVERALL RISK

MEDIUM - no critical unauthenticated compromise was demonstrated. Risk is driven by three Medium browser/infrastructure weaknesses, one Low/Medium TLS hardening gap, an unsupported Next.js version, and unresolved chatbot authorization testing.

Assessment outcome

The assessment combined Qualys external scanning with subdomain enumeration, Certificate Transparency review, DNS validation, Nmap and httpx probing, curl/header analysis, ffuf discovery, Wappalyzer fingerprinting, and limited Burp Suite chatbot testing. The supplied evidence covers public-facing behavior only and does not establish full application, API, or authenticated role coverage.

Qualys reported 30 items against 41.224.33.198: two confirmed vulnerabilities and 28 informational results, with an average risk score of 2.0. Manual correlation retained four validated security findings: F5 BIG-IP persistence-cookie disclosure, a cookie missing the Secure attribute, a missing Content-Security-Policy header, and legacy TLS 1.2 cipher suites.

Assessment disposition

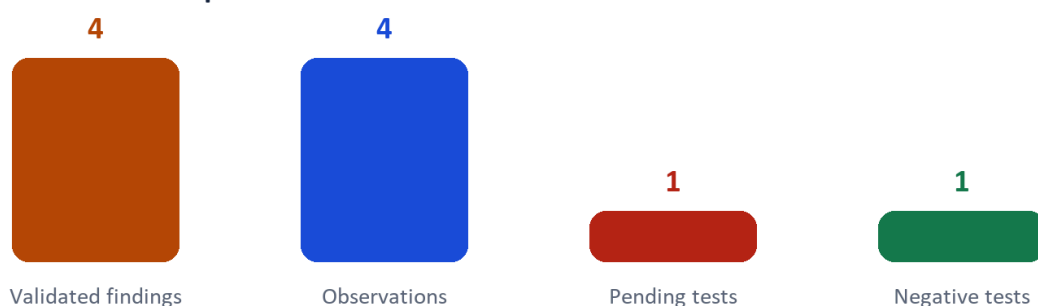


Figure 1 - Final disposition after manual evidence review. Observations and pending hypotheses are excluded from the validated vulnerability count.

Immediate management decisions

Priority	Decision	Why it matters
P0	Encrypt F5 persistence cookies and remove backend address encoding	Stops disclosure of internal IP and port information.
P0	Add Secure, HttpOnly, and appropriate SameSite attributes to every cookie	Prevents unintended plaintext transmission and improves browser-side protections.
P1	Deploy CSP in Report-Only mode, then enforce an approved policy	Reduces browser-side script and injection impact.

Priority	Decision	Why it matters
P1	Upgrade Next.js from 12.3.0 and verify deployed architecture	Removes unsupported software and closes conditional CVE exposure.
P1	Complete authenticated chatbot/API authorization testing	Closes the most consequential unresolved business-logic risk.

01

Executive Summary - Risk Register

ID	Title	Class	Severity	Confidence
W-01	F5 BIG-IP cookie exposes internal IP and port	Validated	Medium	High
W-02	Cookie missing Secure attribute	Validated	Medium	High
W-03	Missing Content-Security-Policy	Validated	Medium	High
W-05	Legacy TLS 1.2 cipher suites enabled	Validated	Low / Medium	High
W-04	Outdated Next.js 12.3.0	Observation	Medium conditional	Medium
W-06	Certificate expires 15 Sep 2026	Observation	Low / Medium	High
W-07	Technology and infrastructure fingerprinting	Observation	Low	High
W-10	Public subdomain exposure through CT logs	Observation	Contextual	Medium
W-08	Manual chatbot injection tests	Negative test	Informational	Medium
W-09	Chatbot/webhook authorization weakness	Pending	Medium / High if confirmed	Low

What was not proven

- No critical remote compromise, command execution, SQL injection, cross-site scripting, or authentication bypass was demonstrated.
- CVE-2025-29927 was version-applicable, but middleware-based authorization bypass was not reproduced; tested endpoints continued returning HTTP 401.
- CVE-2024-47831 requires confirmation that the default Next.js image optimizer is enabled and reachable.
- CVE-2025-66478 is not applicable to the observed Next.js 12.3.0 / Pages Router-era behavior based on the official affected-version scope.
- Chatbot, WebSocket, webhook, and conversation authorization remain pending because authenticated multi-user testing was not evidenced.

CONFIDENCE

High confidence reflects direct response/header, TLS, command, or scanner output. Low confidence reflects a plausible business-logic scenario that was not exercised with authenticated users or backend evidence.

Engagement Overview

Scope, target identity, evidence boundaries, and the external attack surface observed in the supplied material.

Assessment objectives

- Identify externally observable weaknesses across Orange Tunisia public web assets.
- Validate high-value scanner results through response, header, TLS, and manual evidence.
- Assess exposed technologies, certificate lifecycle, cookie controls, and browser hardening.
- Probe chatbot-related input handling and identify authorization scenarios requiring deeper testing.
- Separate confirmed weaknesses from reconnaissance, negative results, and untested hypotheses.

Material limitations

- No signed rules of engagement, full assessment dates, or emergency contacts were attached.
- No authenticated accounts, role matrix, or multiple test identities were documented.
- The raw Qualys PDF/CSV containing all 30 individual records was not supplied; only the summary and selected evidence were available.
- No source code, package-lock inventory, Next.js configuration, WAF/F5 configuration, API schema, or backend logs were available.
- OpenVAS/GVM coverage was not completed because the local setup was not stable.
- ffuf was listed as used, but no complete path/result inventory was included.

Reconnaissance and Technology Evidence

Certificate Transparency and subdomain discovery

crt.sh and subfinder identified multiple Orange Tunisia names. CT publication is expected behavior for publicly trusted certificates; the security value is in detecting forgotten, staging, legacy, or business-specific services that should not remain unmanaged.

Observed name	Disposition in this assessment
staging-atlas.orange.tn	Staging-like name; inventory and access review required
atlas.orange.tn	Inventory and ownership review required
radioalfalleh.orange.tn	Business-specific name; inventory review required
formations.orange.tn	Inventory and ownership review required
revuedepresse.orange.tn	Inventory and ownership review required
messaging-pro-v2.orange.tn	Messaging-related name; authentication review required
reporting.businesssecurity.orange.tn	Reporting-related name; access review required
contact.orange.tn	Inventory and ownership review required
prm.sso.orange.tn	SSO-related name; access and lifecycle review required

Nmap service and header enumeration

```
(harzalls@kali)-[~]
$ nmap -A 41.224.33.232

Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-25 12:09 EDT
Nmap scan report for 41.224.33.232
Host is up (0.0015s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  http-proxy   F5 BIG-IP load balancer http proxy
|_http-server-header: BigIP
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Did not follow redirect to https://41.224.33.232/
443/tcp    open  ssl/https
|_ssl-cert: Subject: commonName=www.orange.tn/organizationName=Orange SA/countryName=FR
|_Subject Alternative Name: DNS:www.orange.tn, DNS:orange.tn
|_Not valid before: 2025-09-13T00:00:00
|_Not valid after: 2026-09-15T23:59:59
|_http-title: Orange Tunisie : Découvrez nos offres mobiles et internet | O...
|_fingerprint-strings:
|_GetRequest:
|_  HTTP/1.1 200 OK
|_  Date: Thu, 25 Jun 2026 16:09:19 GMT
|_  Content-Type: text/html; charset=utf-8
|_  Content-Length: 138669
|_  Connection: close
|_  x-nextjs-cache: HIT
|_  ETag: "13jx67on1b92ye0"
|_  Cache-Control: s-maxage=2, stale-while-revalidate
|_  Vary: Accept-Encoding
|_  Set-Cookie: persistsEshopFE=4245494026.20480.0000; path=/; Httponly
|_  Set-Cookie: TS01bb09db=01bf84ad610fb787276a4e9965d98b92766156c000f9a1b90190e2666a1ace70e9a57587c0154984f35b12a6e87ff0ded6fa397c047e573cd383435bf8a1cc3bd2ed204f5b; Path=/
|_  <!DOCTYPE html><html dir="ltr" prefix="og: https://ogp.me/ns#" lang="fr"><head><script>
|_  APP_ID = "84b030e37c444eceaad7e4789f6520f6";
|_  (function (c, a, A, s, t, J, S) {
|_  (!a.getElementById('caast_library')) {
|_  (c[t] = c[t]), (J = a.createElement(A)), (S = a.getElementsByTagName(A)[0]);
|_  J.async = 1;
|_  J.src = s;
|_  J.id = 'caast_library';
|_  S.parentNode.insertBefore(J, S);
|_  })(window, document, "s
|_  HTTPOptions:
|_  HTTP/1.1 200 OK
```

Figure 2 - Nmap evidence for 41.224.33.232: port 80 redirect behavior, HTTPS service, certificate validity, BigIP header, Next.js cache header, and persistence cookies.

The evidence shows port 80 open with a redirect to HTTPS, port 443 serving the public website, Server: BigIP on port 80, x-nextjs-cache: HIT on HTTPS, persistence cookies, TLS 1.2 and TLS 1.3, and a DigiCert RSA 2048-bit certificate for www.orange.tn / orange.tn expiring 15 September 2026.

IP 41.224.33.232 : main IP of orange.tn

Technology inventory

- Infrastructure and frameworks: F5 BIG-IP, Nginx, Next.js 12.3.0, React, Tailwind CSS, Handlebars, core-js 3.21.0, Swiper, WebSocket, and PWA behavior.
- Analytics and third parties: Google Tag Manager, Google Analytics, Facebook Pixel, LinkedIn Insight Tag, Crazy Egg, and Caast.tv.
- Technology detection is a reconnaissance lead. It becomes a security finding only when tied to a vulnerable configuration, unsupported version, exposed interface, or demonstrated impact.

03

Methodology and Risk Model

Evidence-led external testing and explicit disposition rules for scanner results and manual hypotheses.

Tools and purpose

Tool	Purpose
subfinder	Subdomain enumeration
crt.sh	Certificate Transparency discovery
nslookup	DNS resolution
httpx	Live host probing and HTTP metadata
ffuf	Directory and content discovery
curl	Manual requests, header review, and injection attempts
Burp Suite	Manual request testing and chatbot/API observation
Wappalyzer	Technology fingerprinting
Nmap	Port, service, header, certificate, and TLS enumeration
Qualys	External vulnerability scanning

Assessment workflow

1. Perform passive discovery using CT logs and subfinder.
2. Resolve selected assets and identify live HTTP services.
3. Enumerate ports, redirects, headers, certificates, cookies, and TLS configuration.
4. Fingerprint technologies and review version-specific advisories.
5. Perform directory/content discovery and limited chatbot/API input testing.
6. Correlate Qualys output with manual evidence and classify each result as validated, contextual, negative, pending, excluded, or limited.

Decision rules

- A missing header or cookie attribute is validated when the insecure response state is directly observed or supported by scanner evidence.
- A version match alone does not prove a CVE is exploitable; feature, architecture, route reachability, and mitigations must be validated.
- CT-log names and technology fingerprints are attack-surface observations, not vulnerabilities by themselves.
- Negative injection results are retained to show tested coverage and prevent unsupported claims.
- Business-logic and authorization risks remain pending until reproduced with approved identities and request evidence.

04

Validated Findings

Only weaknesses supported by sufficient technical evidence are included in the validated count.

W-01 VALIDATED	F5 BIG-IP Cookie Exposes Internal IP and Port
Severity	Medium
Status	Confirmed
Affected asset	41.224.33.198:443 : IP of chatbot
Evidence sources	Qualys; Nmap header review
Category	Information disclosure / load-balancer configuration

DESCRIPTION

An F5 BIG-IP persistence cookie disclosed the internal backend IP address and service port behind the public load balancer.

TECHNICAL EVIDENCE

OBSERVED HEADER	Set-Cookie: ltmchatbot=1779439882.14596.0000; path=/; HttpOnly
DECODED BACKEND	10.25.16.106:1081

Nmap corroborated F5 behavior through Server: BigIP on port 80 and persistence cookies on port 443. The evidence proves infrastructure disclosure; it does not prove the private address is reachable from the Internet.

BUSINESS IMPACT

- Discloses a private IP address and backend service port.
- Reveals load-balancer and routing architecture.
- Improves attacker reconnaissance and targeting when chained with another weakness.

SEVERITY JUSTIFICATION

Medium: the disclosure meaningfully assists internal network mapping, but no direct access to the disclosed backend was demonstrated.

REMEDIATION

1. Enable F5 BIG-IP cookie encryption.
2. Review persistence-profile configuration and remove cleartext backend address encoding.
3. Regenerate persistence cookies after configuration changes.
4. Retest with Qualys and manual curl/Nmap header review.

W-02 DETAILED FINDING

W-02 VALIDATED	Session or Persistence Cookie Missing Secure Attribute
Severity	Medium
Status	Confirmed
Affected asset	41.224.33.198:443
Evidence sources	Qualys; Nmap headers
Category	Cookie security

DESCRIPTION

A persistence cookie was set without the Secure attribute. Such a cookie can be sent over an unencrypted HTTP request to the same host if browser behavior and routing permit it.

TECHNICAL EVIDENCE

QUALYS HEADER	Set-Cookie: ltmchatbot=1762662666.14596.0000; path=/; HttpOnly
----------------------	--

Nmap also observed orange.tn persistence cookies including persistsEshopFE and TS01bb09db. At least one captured cookie showed HttpOnly without a visible Secure attribute. The ltmchatbot evidence is confirmed; each additional cookie should be verified independently.

BUSINESS IMPACT

- Potential interception if the cookie is sent over HTTP.
- Persistence or load-balancer routing manipulation.
- Possible user impersonation only if an affected cookie also carries authenticated session state.

SEVERITY JUSTIFICATION

Medium: the proven cookie appears to be load-balancer persistence state rather than a confirmed authentication token. Severity should increase if any authentication cookie is affected.

REMEDIATION

1. Set Secure and HttpOnly on all applicable cookies.
2. Use SameSite=Lax by default and SameSite=Strict for sensitive session cookies when compatible.
3. Enforce HTTPS and HSTS after confirming subdomain readiness.
4. Inventory every Set-Cookie response and verify authentication cookies separately.

SECURE PATTERN	Set-Cookie: <name>=<value>; Path=/; Secure; HttpOnly; SameSite=Lax
-----------------------	--

W-03 DETAILED FINDING

W-03 VALIDATED	Missing Content-Security-Policy Header
Severity	Medium
Status	Confirmed
Affected asset	41.224.33.198:443 / public website
Evidence sources	Qualys; HTTP header review
Category	Browser security headers

DESCRIPTION

The Content-Security-Policy response header was not detected. CSP restricts which scripts, frames, styles, images, and other resources may execute or load in the browser.

TECHNICAL EVIDENCE

QUALYS RESULT Content-Security-Policy HTTP header missing on port 443.

The missing policy is especially relevant because the page includes multiple analytics and third-party components: Google Analytics, Google Tag Manager, Facebook Pixel, LinkedIn Insight Tag, Crazy Egg, and Caast.tv.

BUSINESS IMPACT

- Weaker defense-in-depth against XSS and malicious script injection.
- Reduced control over third-party resource loading and browser-side data exfiltration.
- Weaker clickjacking protection when frame restrictions are also absent.

SEVERITY JUSTIFICATION

Medium: CSP does not fix injection vulnerabilities, but a well-designed policy materially limits exploit impact and unauthorized content loading.

REMEDIATION

1. Deploy Content-Security-Policy-Report-Only and collect violations.
2. Inventory all required first- and third-party origins.
3. Remove unsafe-inline and unsafe-eval dependencies where feasible.
4. Enforce the tested policy and monitor reports.

STARTING POLICY default-src 'self'; object-src 'none'; base-uri 'self'; frame-ancestors 'self'; upgrade-insecure-requests

W-05 DETAILED FINDING

W-05 VALIDATED	Legacy TLS 1.2 Cipher Suites Enabled
Severity	Low / Medium
Status	Confirmed
Affected assets	orange.tn; 41.224.33.198
Evidence sources	Nmap TLS scan; Qualys
Category	TLS hardening

DESCRIPTION

TLS 1.2 and TLS 1.3 are enabled and SSLv2, SSLv3, TLS 1.0, and TLS 1.1 were reported disabled. However, the TLS 1.2 configuration still permits static RSA key exchange, CBC, SHA-1 MAC, and Camellia suites.

TECHNICAL EVIDENCE

Qualys and Nmap both listed TLS 1.2 and TLS 1.3. Enumerated TLS 1.2 choices included AES-GCM alongside older AES-CBC, RSA, DHE/ECDHE, SHA-1, and Camellia options.

BUSINESS IMPACT

Strong modern options are available, so this is not a direct critical weakness. Retaining legacy suites increases cryptographic attack surface and may conflict with current hardening baselines.

SEVERITY JUSTIFICATION

Low / Medium: secure protocols and modern ciphers are present, but unnecessary legacy choices should be removed where client compatibility permits.

REMEDIATION

1. Prefer TLS 1.3.
2. For TLS 1.2, retain ECDHE with AES-GCM suites.
3. Disable static RSA key exchange, CBC, SHA-1 MAC, and Camellia where feasible.
4. Retest with Nmap and Qualys across supported client profiles.

05

Security Observations

Confirmed conditions requiring hardening or validation, but not counted as proven exploits.

W-04 OBSERVATION	Outdated Next.js 12.3.0 Detected
Status	Version indicated by Wappalyzer and x-nextjs-cache; exact package inventory not supplied
Affected asset	Orange public website
Evidence sources	Wappalyzer; Nmap; manual advisory review
Category	Unsupported dependency / conditional CVE exposure

EVIDENCE

Wappalyzer identified Next.js 12.3.0 and the Nmap response included x-nextjs-cache: HIT. This confirms Next.js behavior and a reported version signal, but internal package inventory is required to conclusively establish the deployed package and build.

CVE APPLICABILITY - CVE-2025-29927

Next.js 12.3.0 falls within the affected range for middleware authorization bypass and is below the patched 12.3.5 release. Exploitation requires authorization decisions implemented in vulnerable Next.js middleware. Manual requests to /channel, /content, and /menu continued returning HTTP 401, so bypass was not reproduced and backend or infrastructure authorization may be responsible.

CVE APPLICABILITY - CVE-2024-47831

The detected version is within the affected range for image-optimization denial of service. Applicability depends on whether the default /_next/image optimizer is enabled and reachable; applications using images.unoptimized, a non-default loader, or Vercel hosting are excluded by the advisory. This configuration was not supplied and remains pending validation.

CVE APPLICABILITY - CVE-2025-66478

The official advisory affects Next.js 15.x, 16.x, and certain 14.3 canary builds using React Server Components/App Router. Stable Next.js 12.3.0 and Pages Router applications are outside that scope. No App Router or React Server Components exposure was demonstrated; this CVE is not considered applicable to the observed architecture.

CLASSIFICATION	The unsupported version is a confirmed maintenance risk. High-impact CVE exploitation was not demonstrated; severity remains conditional until internal architecture and feature use are verified.
-----------------------	--

REMEDIATION

1. Upgrade to a currently supported, fully patched Next.js release and test the migration.
2. Confirm the deployed version from package-lock/package inventory rather than browser fingerprinting alone.
3. Block external x-middleware-subrequest headers at F5/nginx until middleware exposure is ruled out.
4. Verify /_next/image configuration and test only in an approved environment.

5. Add software composition analysis and dependency update gates to CI/CD.

W-06 DETAILED FINDING

W-06 OBSERVATION	TLS Certificate Expiration on 15 September 2026
Status	Confirmed lifecycle condition; certificate valid at assessment time
Affected assets	chatbot.orange.tn; orange.tn / www.orange.tn certificate family
Evidence sources	Qualys; Nmap TLS scan
Category	Certificate lifecycle management

TECHNICAL EVIDENCE

Qualys and Nmap reported expiry at 2026-09-15 23:59:59 GMT for the relevant DigiCert certificate family. From the professional edition date, approximately 73 days remain.

BUSINESS IMPACT

Failure to renew before expiry can trigger browser warnings, service-access failures, user distrust, secure-channel disruption, and brand impact.

REMEDIATION

1. Renew and deploy the certificate before expiration.
2. Configure owner-backed alerts at 60, 30, 14, and 7 days.
3. Validate the certificate chain, SANs, stapling, and all load-balancer nodes after deployment.
4. Automate certificate inventory and renewal where operationally feasible.

W-07 OBSERVATION	Technology and Infrastructure Fingerprinting
Status	Confirmed reconnaissance exposure
Affected area	orange.tn; scanned IPs; discovered subdomains
Evidence sources	Wappalyzer; Nmap; crt.sh; subfinder; Qualys
Category	Reconnaissance / information disclosure

EVIDENCE AND IMPACT

The public responses and CT data disclose F5 BIG-IP, Nginx, Next.js, React, WebSocket/PWA behavior, exact library/version signals, analytics providers, and domain naming patterns. These clues support targeted exploit selection and architecture mapping, but are not independently exploitable.

REMEDIATION

1. Remove unnecessary server and version headers.
2. Patch frameworks and libraries; do not rely on obscurity.
3. Maintain an external asset inventory and monitor CT logs.
4. Review exposed staging and business-specific services for ownership and access controls.

W-10 DETAILED FINDING

W-10 OBSERVATION	Public Subdomain Exposure Through CT Logs
Status	Confirmed CT/subfinder discovery; live reachability and vulnerability not established
Affected area	Orange Tunisia subdomain ecosystem
Evidence sources	crt.sh; subfinder
Category	External attack-surface management

DESCRIPTION

Public certificate records exposed staging-like, SSO, messaging, reporting, contact, and business-specific names. This is expected for public certificates, but it can reveal unmanaged or forgotten assets to attackers.

REMEDIATION

1. Maintain a live inventory with owner, purpose, environment, data classification, and lifecycle state.
2. Review all observed names and include authorized assets in future scans.
3. Require strong authentication for non-public services.
4. Remove obsolete DNS records and certificates.
5. Continuously monitor CT logs for new and unexpected issuance.

06

Negative and Pending Tests

Coverage evidence and high-value hypotheses that must not be confused with confirmed vulnerabilities.

W-08 NEGATIVE TEST	Manual Injection Testing Against Chatbot Produced No Confirmed Impact
Status	Tested; no confirmed exploit
Affected component	Chatbot / web input handling
Evidence sources	Burp Suite; curl
Category	Negative test result

TEST RESULT

Injection-style inputs were submitted to chatbot-related behavior. The application accepted typed input and returned HTML or normal responses, but the supplied evidence did not demonstrate XSS execution, command execution, SQL injection, authentication bypass, data leakage, or privilege escalation.

INTERPRETATION

Returning HTML is not itself a vulnerability. This result documents tested coverage; it does not prove every authenticated route or input context is safe.

ASSURANCE ACTIONS

- Continue server-side validation and context-aware output encoding.
- Deploy CSP as defense-in-depth.
- Monitor suspicious inputs and retest authenticated contexts where authorized.

W-09 DETAILED FINDING

W-09 PENDING	Potential Chatbot / Webhook Authorization Weakness
Status	Pending validation
Affected component	Chatbot / WebSocket / webhook / API logic
Evidence sources	Burp Suite; curl; manual analysis
Reason pending	No authenticated multi-user request sequence or successful authorization bypass was supplied
Category	API authorization / business logic

DESCRIPTION

The chatbot appears to rely on web components, WebSocket behavior, webhooks, and backend APIs. Manual testing did not confirm exploitation, but authorization and session binding remain important targets because business-logic flaws are often invisible to external scanners.

RISK SCENARIOS TO VALIDATE

- Change conversation or author identifiers to test cross-user access.
- Call webhook endpoints without authentication or with an invalid verification_token.
- Inject messages without an authenticated user session.
- Reuse or swap WebSocket identifiers across users, sessions, origins, and devices.
- Verify CSRF protection for state-changing browser requests.
- Determine whether /channel, /content, and /menu rely on server-side authorization rather than frontend checks.

POTENTIAL BUSINESS IMPACT

- Unauthorized message injection or conversation disclosure.
- User impersonation and privacy violations.
- Access to chatbot administration functions.
- Abuse or disruption of chatbot infrastructure.

REMEDIATION AND SECURE DESIGN

1. Require authentication on every chatbot, webhook, API, and WebSocket operation.
2. Bind conversations and channels to an authenticated subject or signed server-issued identifier.
3. Ignore client-controlled author/user identifiers unless independently authorized.
4. Enforce object-level and function-level authorization server-side.
5. Validate CSRF protections, WebSocket origins, webhook signatures/tokens, and replay defenses.
6. Rate-limit calls, log suspicious activity, and alert on cross-user or high-volume patterns.

CLOSURE EVIDENCE

- Sanitized request/response pairs for two approved users and an unauthenticated client.
- Backend authorization logs showing subject, object, decision, and denial reason.
- Negative cross-user, replay, WebSocket-origin, webhook-token, and CSRF tests.

07

Remediation Roadmap

Sequenced engineering actions with validation evidence and release gates.

Action	Validation evidence
Encrypt F5 persistence cookies and remove backend encoding	Headers no longer disclose backend IP/port
Apply Secure, HttpOnly, and SameSite attributes to every cookie	Cookie inventory and clean response captures
Deploy CSP Report-Only, tune, and enforce	Violation review and enforced production policy
Upgrade Next.js and verify middleware/image architecture	Package inventory, SCA report, regression tests
Renew September 2026 certificates	New chain deployed to every endpoint/node
Harden TLS 1.2 cipher policy	Nmap and Qualys show approved cipher set
Test chatbot/API authorization with approved identities	Negative cross-user and unauthenticated test evidence
Operationalize attack-surface and CT monitoring	Owned inventory, alerts, and review workflow

Conclusion

The Orange Tunisia web environment shows a medium-risk external security profile.

The Qualys scan did not identify critical unauthenticated vulnerabilities, which is positive. However, the assessment found several meaningful issues when combining Qualys with manual reconnaissance, Nmap, Wappalyzer, crt.sh, Burp Suite, and curl.

The most important confirmed issues are the F5 BIG-IP cookie internal IP disclosure, missing Secure cookie attribute, missing Content-Security-Policy, outdated Next.js 12.3.0 exposure, TLS hardening gaps, and certificate lifecycle risk.

The most important pending area is chatbot/API authorization. Manual injection attempts did not produce confirmed impact, but the chatbot/webhook/WebSocket logic should be reviewed more deeply because business-logic and authorization flaws are often not detected by automated scanners.

The recommended next step is to remediate cookie and F5 issues first, upgrade or validate Next.js exposure, then perform authenticated testing of chatbot endpoints and API authorization controls.